Практическое задание. Вариант Б: Рабочая станция бухгалтера

Краткое описание системы: автоматизированное рабочее место (АРМ) бухгалтера - это персональный компьютер, на котором хранятся и обрабатываются финансовые документы: бухгалтерская отчётность, платёжные поручения, персональные данные сотрудников, налоговые декларации, ключи электронной подписи. Система подключена к интернету и корпоративной сети, используется ежедневно, простой или утечка данных приводит к финансовым и юридическим последствиям.

Шаг 1. Объекты уязвимости

1. Жёсткий диск (SSD/HDD) с финансовыми документами - аппаратный

2. Бухгалтерская программа (1С:Бухгалтерия) - программный

3. База данных финансовых документов и персональных данных - информационный

4. Пользователь-бухгалтер - человеческий/организационный

5. Электронная цифровая подпись (ЭЦП) и её носитель - информационный/аппаратный

Шаг 2. Дестабилизирующие факторы

1. Жёсткий диск:

· Износ механических частей и появление битых секторов - внутренний, случайный, постоянный

· Скачок напряжения в электросети - внешний, случайный, разовый

2. Бухгалтерская программа:

· Ошибка в коде обновления, приводящая к сбою - внутренний, случайный, разовый

· Внедрение вредоносного ПО через фишинговое вложение - внешний, преднамеренный, разовый

3. База данных:

· Несанкционированный доступ извне (SQL-инъекция) - внешний, преднамеренный, периодический

· Ошибка пользователя при вводе/удалении записей - внутренний, случайный, разовый

4. Пользователь (бухгалтер):

· Открытие фишингового письма - внешний, преднамеренный, разовый

· Нарушение инструкций по парольной политике - внутренний, случайный, постоянный

5. ЭЦП и носитель:

· Кража или потеря USB-токена - внешний, преднамеренный, разовый

· Компрометация ключа через вредоносное ПО - внешний, преднамеренный, периодический

Шаг 3. Угрозы надёжности

1. Жёсткий диск:

· Отказ диска и полная потеря финансовых документов - отказ

· Повреждение файлов при внезапном отключении питания - потеря целостности

2. Бухгалтерская программа:

· Сбой после обновления, невозможность формировать отчётность - сбой

· Заражение шифровальщиком и блокировка файлов - блокирование доступа

3. База данных:

· Утечка персональных данных сотрудников - утечка данных

· Искажение сумм в документах - потеря целостности / ошибка

4. Пользователь (бухгалтер):

· Ввод ошибочных данных в отчётность - ошибка

· Несанкционированные действия инсайдера - утечка данных

5. ЭЦП и носитель:

· Подписание мошеннических платёжных поручений - утечка / потеря целостности

· Невозможность сдать отчётность в срок - блокирование доступа

Шаг 4. Таблица

Объект уязвимости	Категория	Дестабилизирующий фактор	Классификация фактора	Угроза надежности	Вид угрозы
Жёсткий диск	Аппаратный	Износ и битые секторы	Внутренний, случайный,	Отказ диска и потеря документов	Отказ

			постоянный		
Жёсткий диск	Аппаратный	Скачок напряжения	Внешний, случайный, разовый	Повреждение файлов	Потеря целостности
Бухгалтерская программа	Программный	Ошибка в обновлении	Внутренний, случайный, разовый	Сбой и невозможность отчётности	Сбой
Бухгалтерская программа	Программный	Фишинговое вложение	Внешний, преднамеренный, разовый	Шифрование файлов	Блокирование доступа
База данных	Информационный	SQL-инъекция	Внешний, преднамеренный, периодический	Утечка персональных данных	Утечка данных
База данных	Информационный	Ошибка ввода/удаления	Внутренний, случайный, разовый	Искажение сумм	Потеря целостности
Пользователь (бухгалтер)	Человеческий	Открытие фишинга	Внешний, преднамеренный, разовый	Ввод ошибочных данных	Ошибка
Пользователь (бухгалтер)	Человеческий	Нарушение парольной политики	Внутренний, случайный, постоянный	Несанкционированный доступ	Утечка данных
ЭЦП и носитель	Информационный/аппаратный	Кража USB-токена	Внешний, преднамеренный, разовый	Подписание мошеннических поручений	Утечка / Потеря целостности
ЭЦП и носитель	Информационный/аппаратный	Компрометация ключа	Внешний, преднамеренный, периодический	Блокирование сдачи отчётности	Блокирование доступа

Шаг 5. Меры защиты

1. Отказ диска - регулярное резервное копирование (ежедневно, с хранением копий вне офиса) - техническая

2. Повреждение файлов при скачке напряжения - установка ИБП (UPS) и сетевого фильтра - техническая

3. Сбой после обновления - тестирование обновлений на копии базы, создание точки восстановления - техническая + организационная

4. Шифрование файлов - антивирус с защитой от шифровальщиков, запрет на открытие вложений из подозрительных писем - техническая + организационная

5. Утечка персональных данных - разграничение прав доступа, шифрование БД, регулярный аудит - техническая + организационная

6. Искажение сумм - ведение журнала изменений, ежедневная сверка, двойной контроль - организационная

7. Ввод ошибочных данных - обучение персонала, проверка вводимых данных, автоматические проверки - организационная

8. Несанкционированный доступ - сложные пароли, двухфакторная аутентификация, блокировка при бездействии - техническая + организационная

9. Кража USB-токена - хранение токена в сейфе, использование PIN-кода, немедленная блокировка при утере - организационная + техническая

10. Блокирование отчётности - резервный ключ ЭЦП, дублирование носителя, инструкция на случай инцидента - организационная

Шаг 6. Наиболее опасная угроза

Наиболее опасной угрозой для рабочей станции бухгалтера является компрометация электронной цифровой подписи (ЭЦП) и последующее подписание мошеннических платёжных поручений.

Обоснование:

1. Высокая вероятность - бухгалтер ежедневно использует ЭЦП, часто хранит токен в доступном месте, а фишинговые атаки на бухгалтеров - одна из самых распространённых схем мошенничества.

2. Тяжесть последствий - злоумышленник может подписать платёжные поручения на крупные суммы, перевести деньги на подставные счета. Ущерб может быть необратимым.

3. Юридические последствия - компрометация ключа ЭЦП означает, что все документы, подписанные этим ключом, могут быть признаны недействительными. Это приведёт к срыву отчётности, штрафам и проверкам.

4. Скрытность - мошеннические операции могут быть обнаружены не сразу, а только при сверке или поступлении претензий от контрагентов. За это время деньги уже будут выведены.

5. Сложность восстановления - даже при наличии резервных копий, восстановить доверие к подписи и отменить мошеннические операции крайне сложно, а иногда невозможно.